

Password Policy

Document Management Information

Item	Description		
Document Title:	Password Policy	Version:	1.0
Document No	USGL-ISMS-POL-05	Status	Controlled
Revision Status	00	Release Date:	01-03-2022

	Prepared By	Reviewed By	Approved By
Name	Solomon Asante	Stephen Agbeli	Daniel Eyeson
Signature			
Date	22-02-2022	25-02-2022	28-02-2022

1. Purpose

The purpose of the policy is to outline the acceptable standards for password construction, management, protection and the frequency of their change. Passwords are an important aspect of Information security. They are the front line of protection for user accounts. A poorly chosen password may result in a compromise of entire network. As such, all employees (including external service providers, contractors, interns and other stake holders with access to USGL systems are responsible for taking the appropriate steps, as outlined below, to select and secure their password.

2. Scope

The scope of this policy includes all personnel who are responsible for an account / may need an access to USGL network or its client's non-public information.

It also includes all personnel who have access to any of the USGL system/ equipment / device that resides at any of USGL's facility and supports or requires a password for the purpose of information Security.

3. Policy

3.1 Password Construction

Passwords should have a minimum of eight characters with a mix of alphanumeric and special characters; if a particular system will not support eight-character passwords, then the maximum number of characters allowed by that system shall be used. Passwords shall not consist of well-known or publicly posted identification information. All employees need to adhere the below guidelines.

3.1.1 Password construction guidelines:

Acceptable Methods to Create a Strong Password

- i. Use a minimum of 8 characters. Generally, the more characters you can use, the harder a password is to be cracked or guessed.
- ii. Choose a password that is easy for you to remember but would be hard for another to guess.
- iii. Use mixed case (upper & lower)
- iv. Use special characters and punctuation symbols (Example: _-+!=! @%*&".:./)

Unacceptable Methods to Create a Strong Password

- i. Do not use dictionary or actual words. Non-English words are no more secure than English words.

- ii. Do not use words, numbers, or known or public information associated with you. (e.g. Social security numbers; Names, family names, pet names; birthdays, phone numbers, addresses; etc.)
- iii. Avoid using your login name or any variation of your login name as your password. If your login is 'Fredrick', do not use substitution or letter reordering. Examples would be 'fr3dr1ck', where the 3=e and the 1 (one) = i. Alternatively, do not use kcirderf (backwards) or add a digit to the beginning or end of the word (1fredrick or fredrick1).
- iv. Do not use the same character for the entire password (e.g., '11111111') or use fewer than five unique characters.
- v. Do not use common letter or number patterns for your password (e.g., '12345678' or 'abcdefgh').
- vi. Substitution should not be used on common words or with common substitutions (e.g., 3=E, 4=A, 1=I, 0=O, etc.)
- vii. When changing a password, change to an entirely new password. Do not just rotate through a list of favorite passwords.
- viii. Never write passwords down.
- ix. Never tell anyone your password.
- x. Never reveal your password over the telephone.
- xi. Never hint at your password.
- xii. In a shared system, never use the "Remember Password" feature of application programs such as Internet Explorer, your email program or any other program.
- xiii. Never use your corporate or network password on an account over the internet which does not have a secure login where the web browser address starts with https:// rather than http://
- xiv. Be careful about letting someone see you type your password.

3.2 Password Management

3.2.1 Password Storage

- i. Passwords shall be memorized and never written down or recorded along with corresponding account information or usernames.

- ii. Passwords must not be remembered by unencrypted computer applications such as email. Use of an encrypted password storage application is acceptable, although extreme care must be taken to protect access to said application.
- iii. Exception is provided for auto save only in Chrome browser since Chrome uses a Windows provided API function which makes the encrypted data only decipherable by the Windows user account used to encrypt the password. So essentially, your master password is your Windows account password. As a result, once you are logged into Windows using your account this data is decipherable by Chrome.
- iv. Suppose your computer is stolen and the thief resets your Windows password in order to natively login to your installation. If they were to subsequently try to view the passwords in Chrome or use the Chrome Pass utility, the password data would not be available. The reason is simple as the “master password” (which was your Windows account password prior to them forcefully resetting it outside of Windows) does not match so the decryption fails.
- v. Additionally, if someone were to simply copy the Chrome password SQLite database file and try to access it on another computer, Chrome Pass would display empty passwords for the same reason explained above.

3.3 Password Aging

Password aging is a mechanism that allows the system to enforce a certain lifetime for passwords. While this may be moderately inconvenient for users, it ensures that passwords are changed within regular interval, which is a good security practice. It is recommended to change the passwords often (**i.e. 90 days**) with the new password.

3.4 Password Reuse

Care shall be taken to prevent the compromise of one username/password from compromising the security of multiple systems or resources. Users shall not reuse the username and password combination.

3.5 Password Sharing and Transfer

Passwords shall not be transferred or shared with others unless the user obtains appropriate authorization to do so. When it is necessary to disseminate passwords in writing, reasonable measures shall be taken to protect the password from unauthorized access. For example, after memorizing the password, one must destroy the written record.

3.5 Electronic Transmission

- i. Passwords shall not be transferred electronically over the Internet using insecure methods

- ii. Wherever possible, security protocols including IMAPS, FTPS, HTTPS, etc. shall be used.

4. Compliance of the Policy

- i. Regular awareness training is provided to the users emphasizing the importance of this policy.
- ii. Pass word aging mechanism is used by IT Team.
- iii. Since password security is critical to the security of the organization and everyone, employees.
- iv. Any user found in non-compliance of this policy shall be subject to disciplinary action, up to and including termination of employment.
- v. This policy shall be revisited annually and may include additional changes or updates.